

Common IAM Concepts

Objectives

- Multifactor Authentication (MFA)
- Single Sign-On (SSO)
 - Enables user to login to multiple apps in the same domain
 - Apps are able to authenticate SSO users
- Federation aka Federated Identity Management (FIM)
 - Enables user to login to app across multiple domains
 - "Sign in using your Google account"
 - Apps and Service Providers (SPs) authenticate users with the help of Identity Providers (IdP)
 - Okta
 - OpenID Connect
 - Azure Active Directory
- Privileged Access Management (PAM)
 - Helps to enforce the Principle of Least Privilege
 - A comprehensive approach to privileged access
 - Control, Audit and Monitor ALL privileged identities and activities
 - Both Human and Non-Human
 - Root/Admin
 - Domain
 - Local
 - SSH
 - Service Accounts
 - API Keys
 - Accomplished by implementing controls such as
 - Mandatory key/secrets rotation for privileged access
 - Isolate sensitive assets
 - Enable MFA
- Passwordless
 - Ditch the passwords for "Possession Factors", "Magic Links", or Biometrics
 - Possession Factors
 - Authenticator Apps
 - Hardware Tokens like Ubikey
 - OTPs via SMS
 - Biometrics
 - Fingerprints
 - Magic Links
 - User gets a link that authenticates them
- Cloud Access Security Broker (CASB)

- Enables cloud admins to apply security to 3rd-party Cloud Services
 - Gives granular control over...
 - Device connections (BYOD)
 - Cloud Apps (M\$-365)
 - Data sharing and Loss Prevention (DLP)
 - Other features
 - Encryption and Key Management
 - User and Entity Behavior Analytics (Threat Prevention)
 - Malware Detection
 - Configuration Auditing
- 4 Pillars of CASB
 - Visibility
 - Who/What/When/Where/Why/How are cloud services being used
 - CASB should be able to monitor and control these conditions
 - Compliance
 - Built-In Regulatory compliance
 - Data Security
 - Encryption
 - DLP
 - Threat Protection
 - UEBA
 - Malware Detection/Analysis